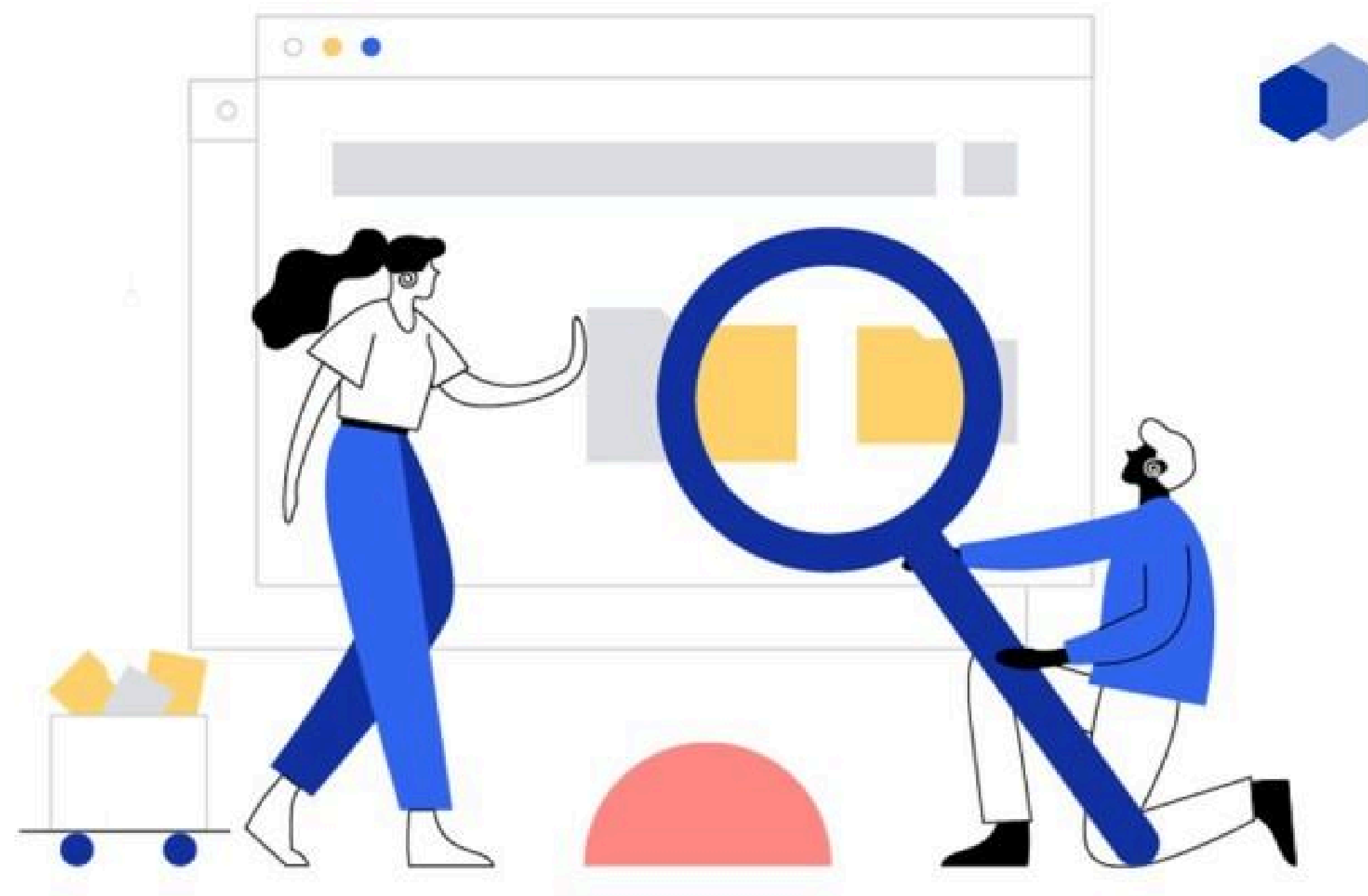
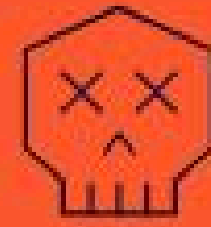


Разработка автоматизированной системы верификации воспроизводимых сборок для обеспечения безопасности цепочек поставок программного обеспечения.



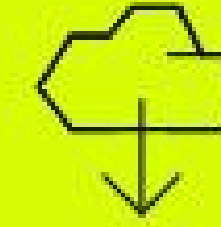
sonatype state of the software supply chain

1,233,219



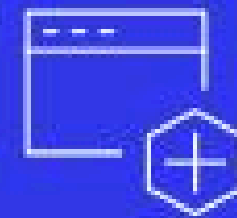
OPEN SOURCE MALWARE PACKAGES LOGGED BY
SONATYPE SINCE 2019

9.8 TRILLION



DOWNLOADS ACROSS MAVEN CENTRAL, PYPI, NPM
AND NUGET

27.76%



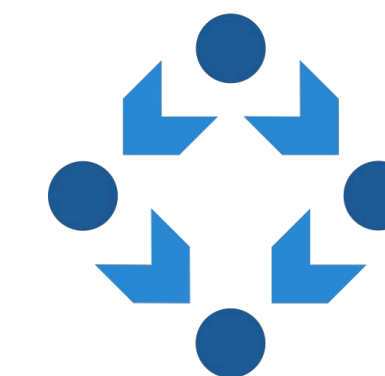
RECOMMENDED DEPENDENCY UPGRADE
HALLUCINATION RATE OBSERVED WITH LEADING LLM

65%



OF OPEN SOURCE CVES WERE LEFT WITHOUT CVSS
BY THE NVD

введение



проблема

разрыв между верифицированным исходным кодом и конечным исполняемым файлом позволяет злоумышленникам внедрять вредоносную нагрузку непосредственно в процесс сборки

цель

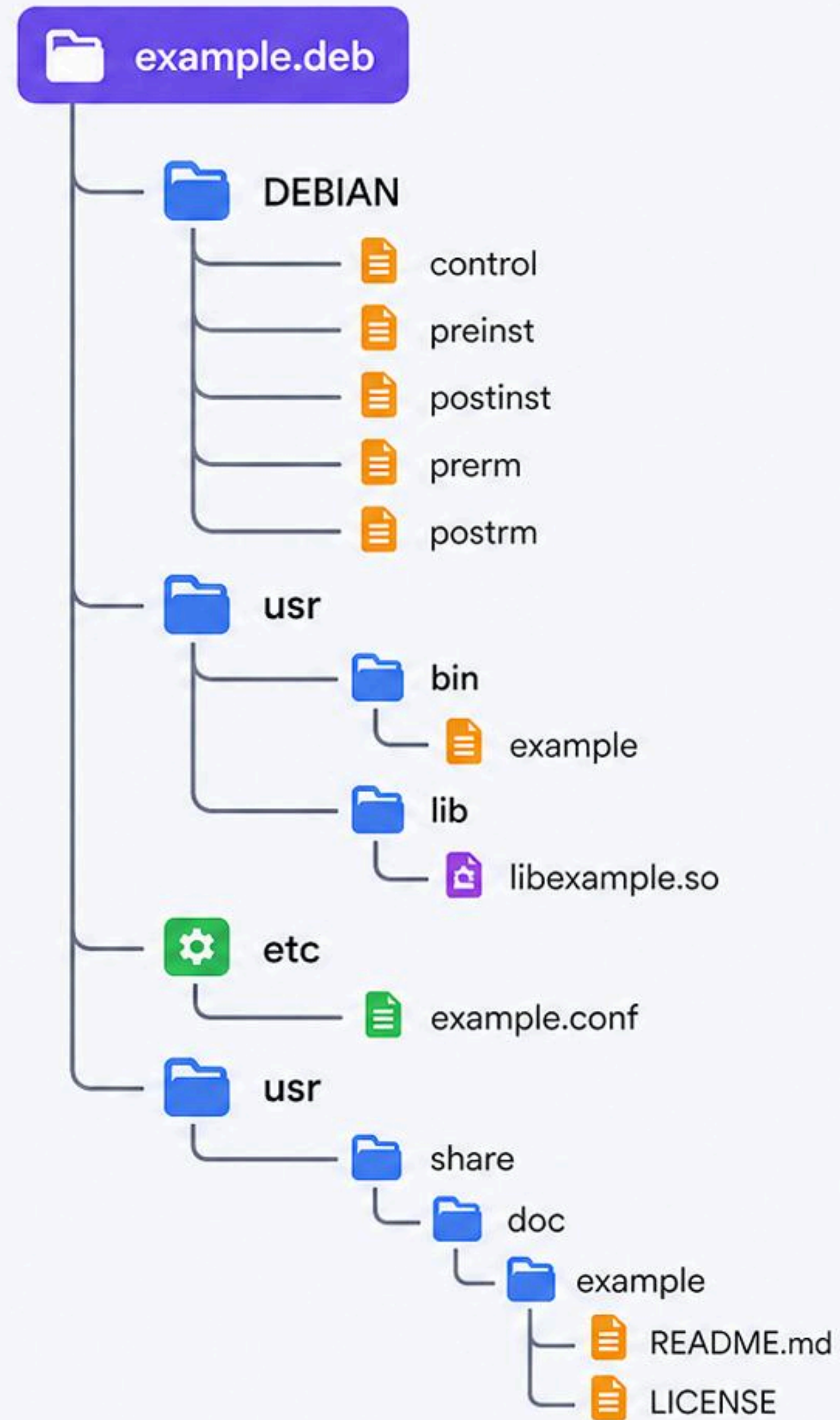
разработка автоматизированной системы верификации воспроизводимых сборок для обеспечения безопасности цепочек поставок программного обеспечения

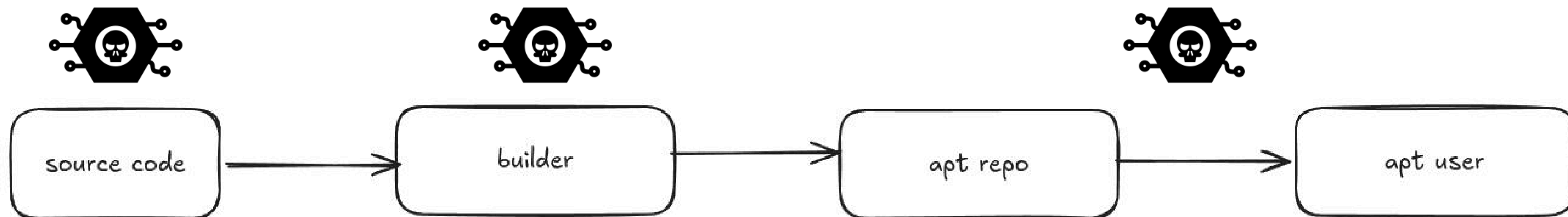
задачи

- выявить векторы атак и факторы нарушения тождественности сборок
- спроектировать архитектуру
- разработать компоненты системы
- провести апробацию на пакетной базе

Legend

-  Root
-  Directory
-  Config File
-  File
-  Library / Shared Object





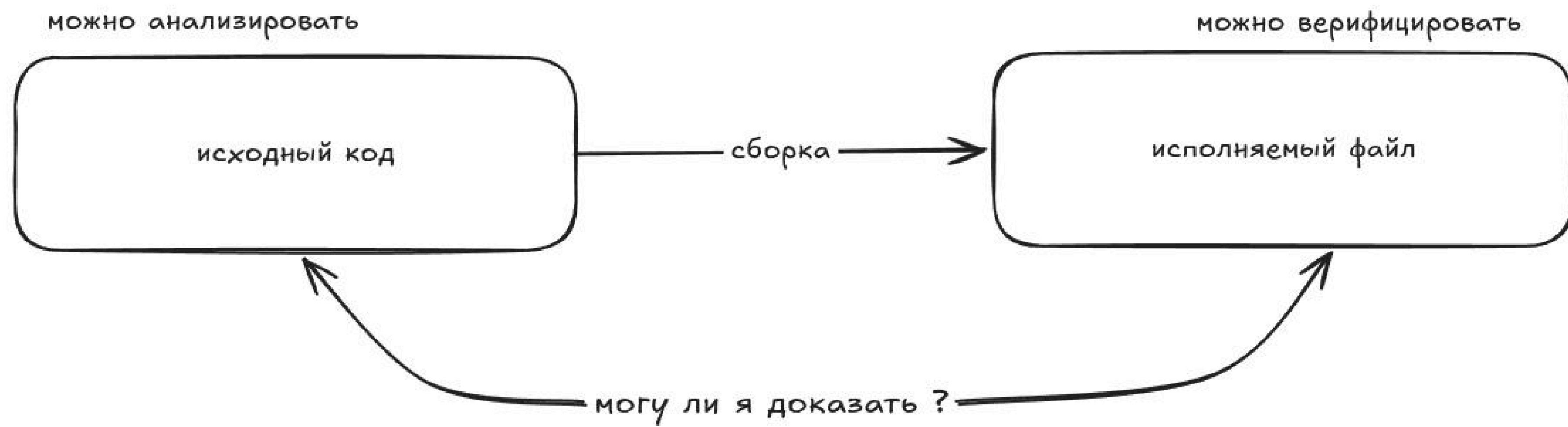
sast/dast

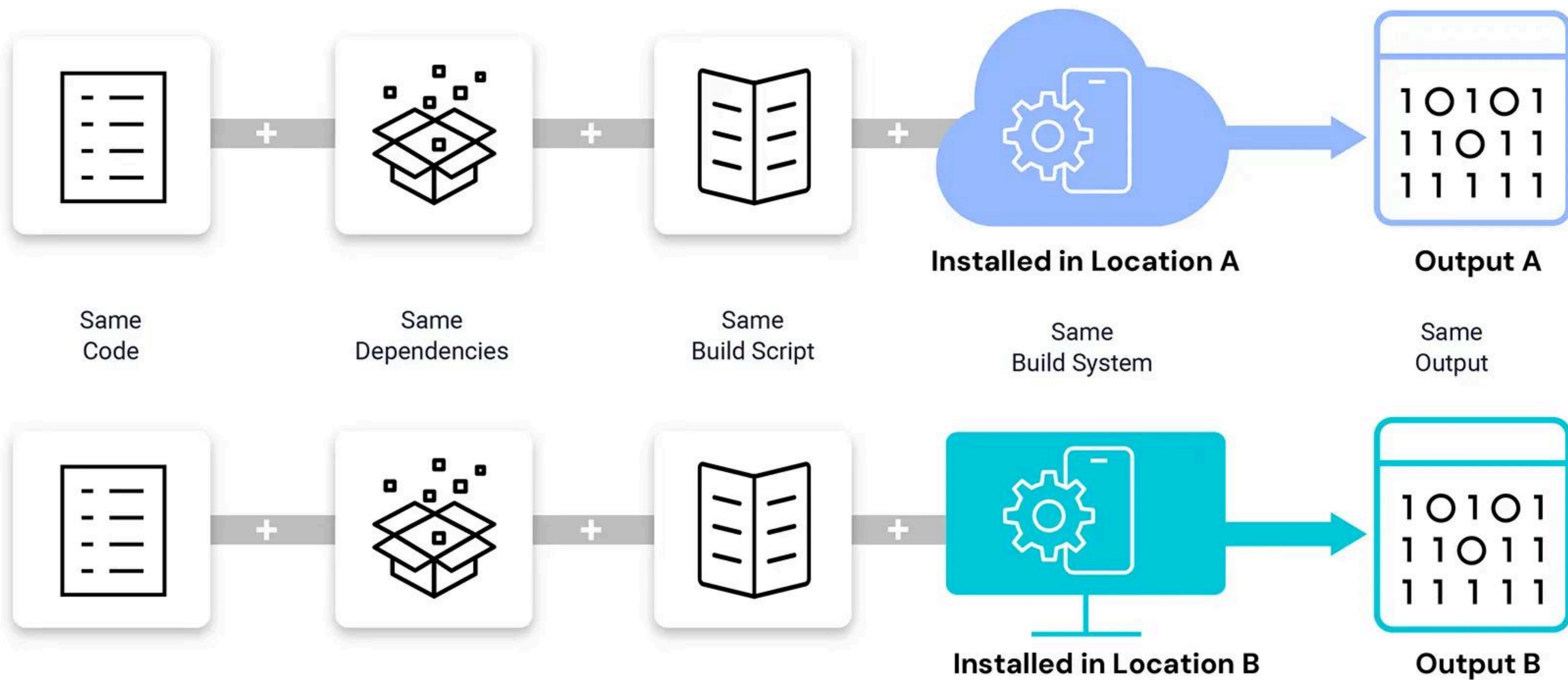
Static & Dynamic
Application Security Testing

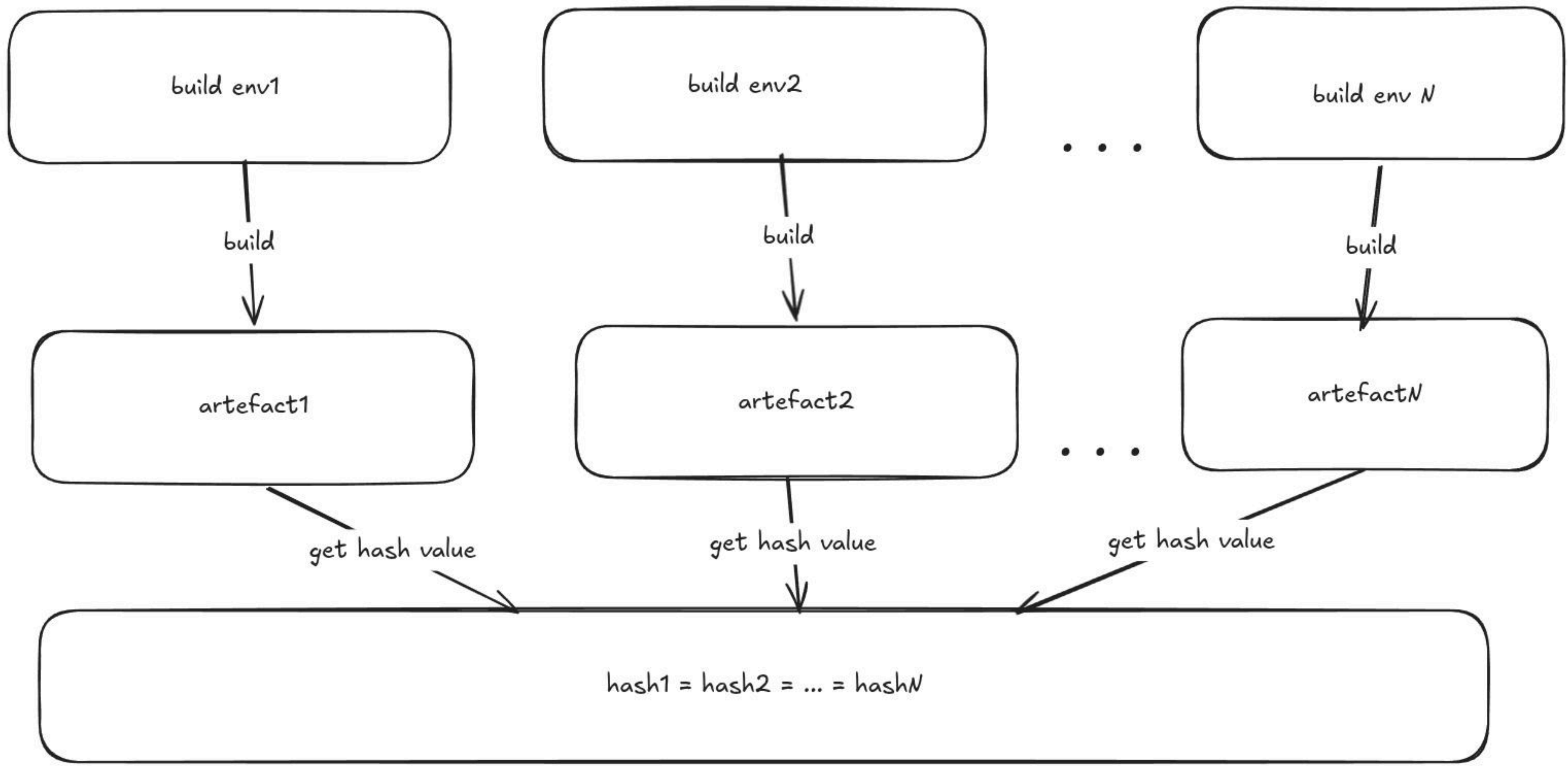


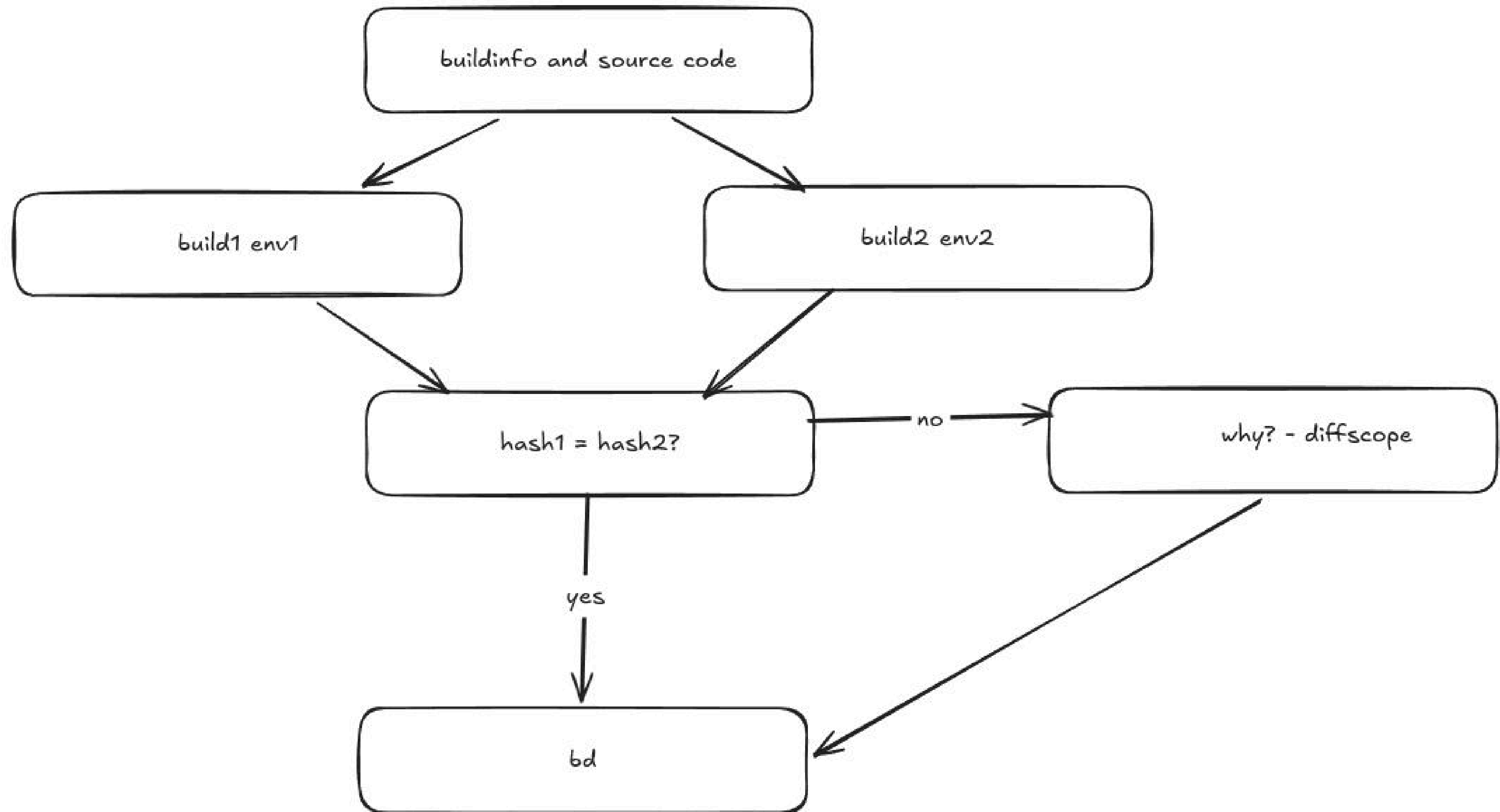
gpg/shasum/tls

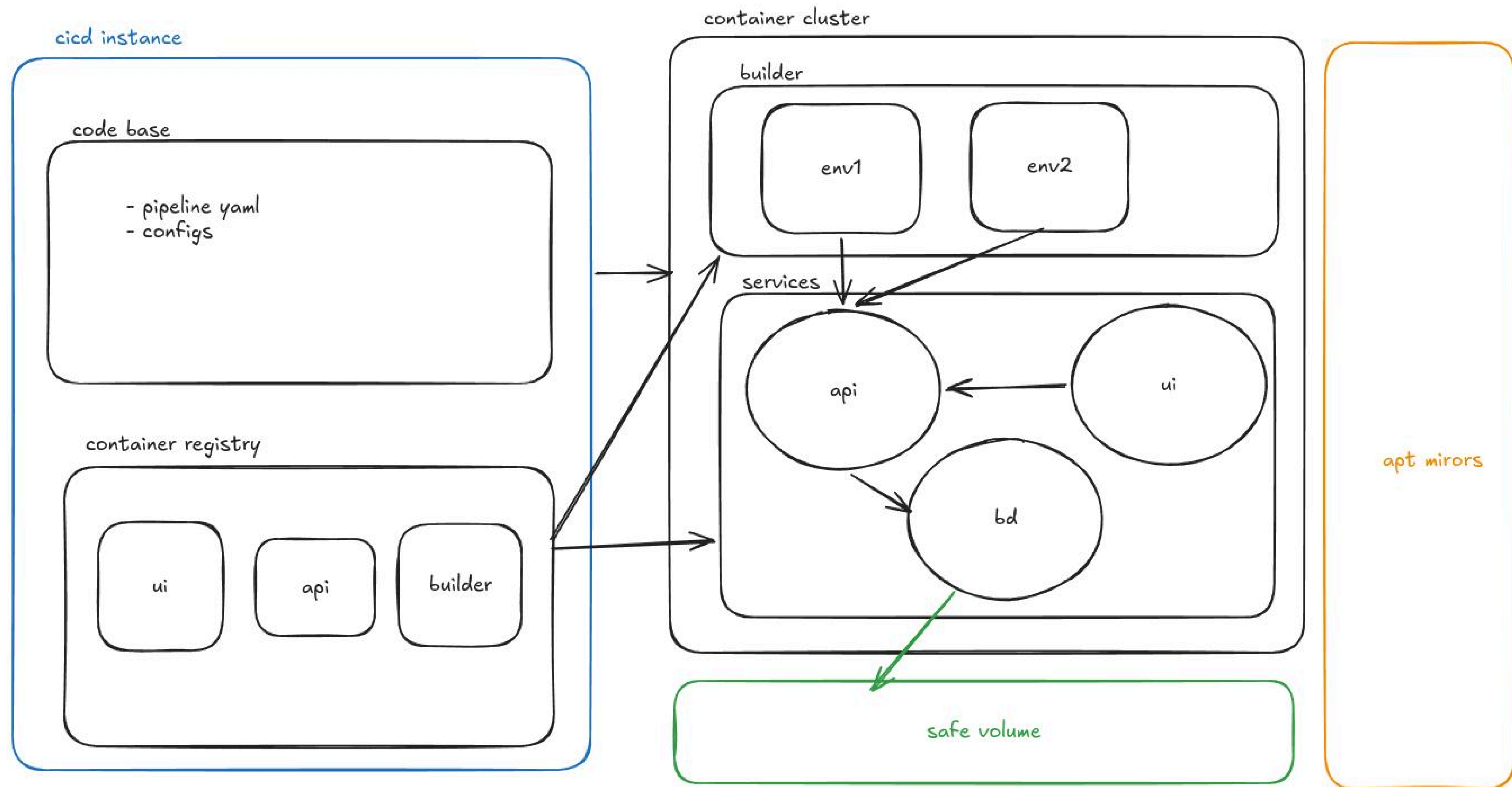
Signing, Checksums
& Encrypted Transport











```
root@master:/home/user# kubectl get pod -A
```

NAMESPACE	NAME	READY	STATUS	RESTARTS	AGE
gitlab-runner	gitlab-runner-74c5484b99-xkqbv	1/1	Running	47 (129m ago)	65d
kube-system	coredns-6587789f44-x79rk	1/1	Running	28 (129m ago)	99d
kube-system	local-path-provisioner-869c44bfbd-vv15n	1/1	Running	39 (129m ago)	121d
kube-system	metrics-server-7bffffcd44-md688	1/1	Running	41 (129m ago)	121d
kube-system	svclb-traefik-6bf0a24f-59m1l	2/2	Running	26 (51d ago)	118d
kube-system	svclb-traefik-6bf0a24f-64jpb	2/2	Running	78 (129m ago)	121d
kube-system	svclb-traefik-6bf0a24f-kjs4x	2/2	Running	16 (67d ago)	118d
kube-system	traefik-58cf6d4ccb-slqht	1/1	Running	28 (129m ago)	103d
reprocheck	api-5dfdc9ff9-c9ns2	1/1	Running	1 (129m ago)	15d
reprocheck	postgres-0	1/1	Running	1 (129m ago)	15d
reprocheck	ui-7475784f48-nl2x7	1/1	Running	1 (129m ago)	15d

```
root@master:/home/user# kubectl get namespaces
```

NAME	STATUS	AGE
default	Active	121d
gitlab-runner	Active	105d
kube-node-lease	Active	121d
kube-public	Active	121d
kube-system	Active	121d
reprocheck	Active	15d

```
root@master:/home/user#
```

```
root@master:/home/user# kubectl get svc -n reprocheck
```

NAME	TYPE	CLUSTER-IP	EXTERNAL-IP	PORT(S)	AGE
api	ClusterIP	10.43.11.124	<none>	80/TCP	15d
postgres	ClusterIP	None	<none>	5432/TCP	15d
ui	ClusterIP	10.43.220.103	<none>	80/TCP	15d

```
root@master:/home/user# kubectl get pods -n reprocheck
```

NAME	READY	STATUS	RESTARTS	AGE
api-5dfdc9ff9-c9ns2	1/1	Running	1 (130m ago)	15d
postgres-0	1/1	Running	1 (130m ago)	15d
ui-7475784f48-nl2x7	1/1	Running	1 (130m ago)	15d

```
root@master:/home/user#
```


Initial commit

Delete

✔ Passed Created 3 hours ago by Administrator, finished 3 hours ago

For commit 3faf03d1

In main

branch 2 jobs 2 minutes 33 seconds, queued for 2 seconds

Pipeline Jobs 2 Tests 0

Group jobs by Stage Job dependencies Show dependencies

Downstream



PACKAGE	VERSION	ARCH	STATUS
python3-pysam	0.20.0+ds-3	amd64	fail
DIFFERING FILES (2/2)			
FILE	SHA256 ENV1	SHA256 ENV2	
python-pysam-tests_0.20.0+ds-3_all.deb	b0826013c24bed28...	b0372f961aaf4d5e...	
python3-pysam_0.20.0+ds-3_amd64.deb	b84500736be4e3a8...	ac57b2184a394514...	

debs_python3-pysam_env1/python3-pysam_0.20.0+ds-3_amd64.deb vs. debs_python3-pysam_env2/python3-pysam_0.20.0+ds-3_amd64.deb

file list536 B

Offset 1, 3 lines modified

Offset 1, 3 lines modified

-rw-r--r--

1

...

10·17:27:42

000000

debian-binary

-rw-r--r--

2

...

10·17:27:42

000000

control.tar.xz

-rw-r--r--

3

...

10·17:27:42

000000

data.tar.xz

-rw-r--r--

1

...

10·17:27:43

000000

debian-binary

-rw-r--r--

2

...

10·17:27:43

000000

control.tar.xz

-rw-r--r--

3

...

10·17:27:43

000000

data.tar.xz

control tar xz1.05 KB

ENV1 — REFERENCE		ENV2 — VARIED	
TZ	UTC	TZ	Asia/Tokyo
LC_ALL	C.UTF-8	LC_ALL	et_EE.UTF-8
LANG	C	LANG	et_EE.UTF-8
umask	0022	umask	0002
user	repro1	user	pbuilder2
hostname	reproducible-env1	hostname	i-am-different
path	/build/first	path	/build/second/subdir
build_env_num	1	build_env_num	2



github.com/j4hongir/reprochek